



Universidad de Jaén

ESCUELA POLITÉCNICA SUPERIOR DE JAÉN

ENTORNO OPERACIONAL, ORGANIZACIONAL Y ALCANCE

Auditoría y seguridad en sistemas de información

Autores:

Raúl Gómez Téllez - rgt00024
Rubén Ramírez Peña - rrp00041
Víctor Aguilar Méndez - vam00022
Jaime M. Cazalla Chica - jmcc0049

Abril 2026

Índice

1. Descripción detallada de la empresa	2
2. Marco Organizativo y Alcance de la Auditoría	3
2.1. Composición de la Plantilla	3
2.2. Estructura Departamental y Enfoque de Auditoría	3
2.2.1. Departamento de Dirección y Estrategia	3
2.2.2. Departamento de Sistemas y TI	3
2.2.3. Departamento de Operaciones (Almacén y Taller)	3
2.2.4. Departamento Comercial y Ventas	3
2.2.5. Departamento de Administración y Compras	4
2.3. Relación entre Espacio Físico y Unidades Lógicas	4
2.4. Consideraciones Críticas para la Auditoría	4
2.5. Información económica y volumen de actividad	4
2.6. Datos relevantes para la auditoría	5
3. Entorno operacional	6
3.1. Instalaciones físicas	6
3.2. Horario de funcionamiento	6
3.3. Infraestructura tecnológica	7
3.4. Red y conectividad	7
3.5. Entorno de continuidad y disponibilidad	7
4. Identificación de activos	8
4.1. Activos humanos	8
4.2. Activos físicos	8
4.3. Activos lógicos y de software	8
4.4. Activos de red y comunicaciones	9
4.5. Activos de información	9
4.6. Activos de negocio y procesos	9
5. Alcance de la auditoría	10
5.1. Elementos incluidos dentro del alcance	10
5.2. Elementos excluidos o fuera del alcance	11
5.3. Justificación del alcance	11
6. Supuestos realizados	12
7. Sesión 2: Identificación, Clasificación y Valoración de Activos	13
7.1. Codificación de Activos para Trazabilidad	13
7.2. Clasificación y Valoración de Datos e Información	13
7.3. Clasificación y Valoración de Sistemas e Infraestructura	13
7.4. Clasificación y Valoración de Personal (Activos Humanos)	14
8. Sesión 3: Mapa de Riesgos - Amenazas y Vulnerabilidades	15
8.1. Identificación de Salvaguardas Existentes	15
8.2. Identificación de Vulnerabilidades	15
8.3. Matriz de Amenazas y Probabilidad	15
8.4. Evaluación de la Vulnerabilidad (Debilidad)	16
9. Sesión 4: Análisis y Gestión de Riesgos	18
9.1. Valoración de Activos	18
9.2. Cálculo del Riesgo Intrínseco y Priorización	18
9.3. Tratamiento del Riesgo y Propuesta de Acciones	18
10. Sesión 5: Controles y Plan de Acción	20
10.1. Propuesta de Controles y Resultados de la Evaluación	20
10.2. Conclusiones de la Auditoría	21

1. Descripción detallada de la empresa

CRP Computers es una pequeña y mediana empresa (PYME) dedicada al montaje, reparación y venta de equipos y componentes informáticos. La organización desarrolla su actividad principal desde una única sede física situada en el Polígono Industrial Los Olivares, C. Escañuela, 19, 23009 Jaén. Además de su actividad presencial, dispone de un servicio de venta online, el cual representa el 35 % de los ingresos totales de la empresa.

Desde el punto de vista del negocio, la empresa combina varias líneas operativas que deben considerarse relevantes en el marco de una auditoría de seguridad:

- venta de componentes y equipos informáticos en tienda física;
- venta de productos a través de tienda online;
- montaje de equipos informáticos;
- reparación de equipos de clientes;
- almacenamiento y gestión de componentes y material tecnológico.

Esta diversidad de actividades implica la existencia de distintos tipos de activos de información y distintos procesos de negocio, algunos orientados a atención al cliente, otros a operaciones internas y otros a servicios tecnológicos. En consecuencia, la superficie de exposición de la empresa no se limita únicamente a los equipos informáticos, sino también a la gestión de clientes, al inventario, a la operativa de taller, al almacenamiento y a la disponibilidad del comercio electrónico.

2. Marco Organizativo y Alcance de la Auditoría

2.1. Composición de la Plantilla

La plantilla de **CRP Computers** está compuesta por 12 trabajadores, cuya distribución funcional es clave para determinar los perfiles de acceso y responsabilidades dentro del sistema de información:

- 1 Director ejecutivo.
- 2 Administradores de sistemas (Servicios informáticos).
- 1 Jefe de almacén y 2 auxiliares de almacén.
- 1 Jefe de taller y 3 técnicos de montaje y reparación.
- 1 Dependiente de atención al público.
- 1 Jefe de compras.
- 1 Administrativo.

2.2. Estructura Departamental y Enfoque de Auditoría

Para realizar una auditoría de sistemas de información exhaustiva, se ha diseñado una departamentalización estratégica que segmenta el alcance y facilita la identificación de riesgos específicos.

2.2.1. Departamento de Dirección y Estrategia

Representa el nivel jerárquico superior y la gobernanza de la empresa.

Composición: Director Ejecutivo.

Activos clave: Planes de negocio, decisiones estratégicas y credenciales de acceso total.

Enfoque de auditoría: Compromiso con la seguridad, gestión de la continuidad de negocio y cumplimiento legal.

2.2.2. Departamento de Sistemas y TI

Es el núcleo técnico de la auditoría debido a la centralización de servicios en un único servidor.

Composición: Dos administradores de sistemas.

Activos clave: Servidor central, infraestructura de red Wi-Fi, fibra óptica y licenciamiento.

Enfoque de auditoría: Políticas de backup, seguridad perimetral, gestión de parches (Windows 10) y resiliencia eléctrica.

2.2.3. Departamento de Operaciones (Almacén y Taller)

Gestiona el flujo físico de mercancía y el servicio técnico de postventa.

Composición: Personal de almacén y técnicos de taller.

Activos clave: Inventario, bases de datos de reparaciones y equipos de clientes (datos de terceros).

Enfoque de auditoría: Seguridad física, trazabilidad de componentes y privacidad de datos en custodia.

2.2.4. Departamento Comercial y Ventas

Canal de generación de ingresos (35 % a través de la plataforma online).

Composición: Dependiente y flujo operativo del e-commerce.

Activos clave: Pasarela de pagos, TPV y base de datos de 3.500 clientes.

Enfoque de auditoría: Cumplimiento del RGPD, seguridad en transacciones y disponibilidad 24/7 de la web.

2.2.5. Departamento de Administración y Compras

Responsable de la integridad financiera y la cadena de suministro.

Composición: Jefe de compras y administrativo.

Activos clave: Software de contabilidad, nóminas y registros de facturación.

Enfoque de auditoría: Integridad de datos financieros y control de acceso a expedientes de empleados.

2.3. Relación entre Espacio Físico y Unidades Lógicas

Para mayor claridad en la memoria, se presenta la siguiente matriz que alinea los departamentos con el entorno físico de la nave industrial:

Planta	Espacio Físico	Departamentos Asociados
Superior	Oficinas y Dirección	Dirección, Administración y Compras
Inferior	Sala de Servidores	Sistemas y TI
Inferior	Almacén y Taller	Operaciones, Taller y Ventas Presenciales

Cuadro 1: Distribución física de los activos y personal por planta.

2.4. Consideraciones Críticas para la Auditoría

La composición actual permite identificar vectores de riesgo específicos que serán analizados en los siguientes apartados:

- **Segregación de funciones:** Riesgo de concentración de privilegios en los administradores de sistemas.
- **Dependencia operativa:** Alta sensibilidad ante la ausencia de figuras clave (Director/TI).
- **Custodia de datos:** Vulnerabilidad potencial en el tratamiento de equipos de clientes en el taller.

2.5. Información económica y volumen de actividad

La empresa tiene registrados 3500 clientes. Asimismo, presenta los siguientes datos medios de operación diaria:

- 32 compras al día;
- 5.525 euros de facturación diaria media por ventas;
- 10 reparaciones diarias de equipos informáticos;
- valor medio por reparación de 150 euros.

Estos datos permiten concluir que CRP Computers maneja un volumen de información no despreciable, especialmente en lo relativo a:

- Datos identificativos y de contacto de clientes;
- Historial de compras;
- Historial de reparaciones;
- Información económica y de facturación;
- Posible información técnica o incluso personal contenida en los equipos entregados para reparación.

Por tanto, la empresa no solo depende de sus sistemas para mantener la continuidad del negocio, sino también para preservar la confidencialidad, integridad y disponibilidad de información potencialmente sensible.

2.6. Datos relevantes para la auditoría

A efectos de una auditoría de seguridad, los datos más relevantes extraídos de la descripción inicial son los siguientes:

- La empresa no cuenta con ningún tipo de control interno de seguridad;
- Existe una única sede física donde se concentra toda la actividad;
- Existe un único servidor físico que centraliza todos los servicios;
- Todos los empleados disponen de un equipo informático;
- Todos los equipos se conectan mediante una red inalámbrica WIFI;
- La empresa depende de Internet tanto para su operativa como para el canal de venta online;
- Se producen cortes de suministro eléctrico en la zona con cierta recurrencia.

Cada uno de estos elementos constituye un factor de relevancia para el análisis posterior del riesgo, especialmente por la posible existencia de puntos únicos de fallo, ausencia de segmentación, debilidad de controles organizativos o dependencia de infraestructura crítica sin redundancia explícita.

3. Entorno operacional

El entorno operacional de CRP Computers está conformado por los medios físicos, lógicos, humanos y de conectividad que permiten el desarrollo diario de su actividad.

3.1. Instalaciones físicas

La empresa dispone de una única nave industrial de 10 metros de fachada por 20 metros de profundidad, distribuida en dos plantas.

Planta superior

En la planta superior se localizan:

- Las oficinas donde se desarrolla la actividad comercial;
- La oficina del director ejecutivo;
- Una sala de reuniones;
- Los servicios.

Planta inferior

En la planta inferior se encuentran:

- La sala de servidores;
- Una pequeña zona de exposición y venta al público;
- Una sala pequeña con cafetera y microondas utilizada como espacio de descanso;
- Los servicios;
- Un almacén/taller en el que se almacenan componentes y se montan y reparan equipos.

Desde el punto de vista de seguridad, esta distribución es importante porque concentra en un único edificio:

- La actividad comercial;
- La actividad administrativa;
- La infraestructura tecnológica;
- El almacenamiento de material;
- La interacción con clientes;
- Los procesos de reparación y montaje.

Esto implica que cualquier incidente físico grave en la nave podría afectar simultáneamente a múltiples procesos críticos del negocio.

3.2. Horario de funcionamiento

La tienda física atiende al público en el siguiente horario:

- De lunes a viernes: de 10:00 a 14:00 y de 17:00 a 20:00;
- Sábados: de 10:00 a 14:00.

La tienda online recibe peticiones las 24 horas del día, los 7 días de la semana, aunque los pedidos se procesan y envían en horario laboral.

Este aspecto tiene implicaciones claras:

- Los sistemas expuestos a Internet deben estar disponibles de forma continua;

- Puede existir una diferencia entre disponibilidad de recepción de pedidos y capacidad de respuesta operativa;
- Una caída de los sistemas fuera del horario presencial puede afectar a ventas sin ser detectada de inmediato.

3.3. Infraestructura tecnológica

Todos los trabajadores disponen de un ordenador con las siguientes características:

- 16 GB de RAM;
- 1 disco duro SSD de 512 GB;
- Procesador Intel i5 de 11^a generación a 2.6 GHz, 8 núcleos, con turbo boost hasta 4.1 GHz;
- Sistema operativo Windows 10;
- Antivirus Panda Advanced.

Además, la organización dispone de un único servidor físico que centraliza todos los servicios.

La centralización en un único servidor convierte a este activo en un elemento crítico, ya que previsiblemente soportará funciones esenciales como almacenamiento de información, servicios internos, bases de datos, autenticación, servicios asociados a la venta online o cualquier otra función central de la organización.

3.4. Red y conectividad

Todos los equipos están conectados a una red inalámbrica WIFI, la cual proporciona conectividad interna y acceso a Internet mediante una conexión de fibra óptica simétrica de 600 MB proporcionada por DIGI.

Desde una perspectiva de auditoría, este punto es especialmente relevante por varios motivos:

- Toda la organización depende de una misma infraestructura de red inalámbrica;
- La seguridad del entorno depende en gran medida de la correcta configuración del WIFI;
- La conexión a Internet es esencial para la tienda online y para posibles tareas administrativas, comerciales y técnicas;
- No se menciona segmentación de red, redes separadas para invitados, ni separación entre sistemas críticos y sistemas de uso general.

3.5. Entorno de continuidad y disponibilidad

Se indica que el promedio de cortes de suministro eléctrico en la zona es de 5 cortes al año, con una duración media estimada de 25 minutos.

Este dato tiene impacto directo sobre:

- La disponibilidad de sistemas;
- La continuidad del negocio;
- La integridad de operaciones en curso;
- La pérdida potencial de servicio en tienda física y online.

La existencia de una única sede y un único servidor hace que la disponibilidad eléctrica sea un factor operacional particularmente sensible.

4. Identificación de activos

A continuación se identifican los activos más relevantes de CRP Computers, agrupados por categorías.

4.1. Activos humanos

- Director ejecutivo.
- Administradores de sistemas.
- Personal de almacén.
- Personal de taller y reparación.
- Dependiente de atención al público.
- Jefe de compras.
- Administrativo.

Los activos humanos son esenciales porque ejecutan los procesos, acceden a la información y pueden ser tanto parte de la defensa como fuente de incidentes por error, abuso de privilegios o falta de formación.

4.2. Activos físicos

- Nave industrial completa.
- Sala de servidores.
- Oficinas.
- Zona de venta al público.
- Almacén/taller.
- Equipos informáticos de usuario.
- Servidor físico central.
- Componentes informáticos almacenados.
- Equipos de clientes en reparación.

Dentro de esta categoría, destacan especialmente el servidor físico, la sala de servidores y los equipos de clientes depositados para reparación.

4.3. Activos lógicos y de software

- Sistema operativo Windows 10 en los puestos de trabajo.
- Solución antivirus Panda Advanced.
- Servicios centralizados en el servidor físico.
- Plataforma o servicio asociado a la tienda online.
- Posibles aplicaciones de gestión comercial, administrativa, de stock y de reparaciones.

Aunque no se detallan expresamente todas las aplicaciones utilizadas, es razonable asumir la existencia de software de gestión comercial, inventario y administración, dado el tipo de actividad desarrollada.

4.4. Activos de red y comunicaciones

- Red WIFI corporativa.
- Conectividad a Internet por fibra.
- Infraestructura de acceso interno a servicios.

Estos activos son críticos porque permiten el funcionamiento coordinado de los puestos de trabajo y la exposición del canal online.

4.5. Activos de información

- Base de datos o registro de 3500 clientes.
- Información de ventas y facturación.
- Información de compras y proveedores.
- Información de inventario y stock.
- Órdenes de reparación.
- Historial técnico de los equipos reparados.
- Información administrativa y contable.
- Posible información contenida en los equipos de clientes entregados para reparación.

Estos activos presentan distinto nivel de criticidad, aunque todos tienen relevancia en términos de confidencialidad, integridad y disponibilidad.

4.6. Activos de negocio y procesos

- Proceso de venta presencial.
- Proceso de venta online.
- Proceso de gestión de pedidos.
- Proceso de montaje de equipos.
- Proceso de reparación.
- Proceso de compras.
- Proceso administrativo.
- Proceso de almacenamiento y gestión de inventario.

La interrupción o deterioro de cualquiera de estos procesos podría afectar directamente a la facturación, a la reputación de la empresa o a su capacidad operativa.

5. Alcance de la auditoría

5.1. Elementos incluidos dentro del alcance

La presente auditoría incluirá, como mínimo, los siguientes elementos:

Infraestructura física

- La nave industrial completa.
- La sala de servidores.
- Las oficinas.
- La zona de tienda y atención al público.
- El almacén/taller.

Infraestructura tecnológica

- Todos los equipos de trabajo de los empleados.
- El servidor físico central.
- La red WIFI corporativa.
- La conectividad a Internet en cuanto a su uso dentro de la organización.

Sistemas y servicios

- Los sistemas operativos de los puestos de usuario.
- El antivirus implantado.
- Los servicios alojados en el servidor.
- La operativa asociada al comercio electrónico.

Información y procesos

- La gestión de clientes.
- La gestión de ventas.
- La gestión de reparaciones.
- La gestión de inventario y almacén.
- La gestión administrativa.

Ámbito organizativo

- Los roles y responsabilidades del personal.
- La distribución funcional de tareas.
- Los posibles accesos a información y sistemas.

5.2. Elementos excluidos o fuera del alcance

Quedarán fuera del alcance, salvo que en fases posteriores de la práctica se indique expresamente lo contrario:

- La infraestructura interna del proveedor de Internet;
- Los sistemas externos pertenecientes a terceros que no estén bajo control directo de CRP Computers;
- Auditorías legales o financieras ajenas al ámbito de seguridad de la información;
- Dispositivos personales de empleados, en caso de existir, ya que no se mencionan en la descripción inicial;
- Instalaciones distintas de la sede principal, dado que no se indica la existencia de otras sedes;
- Servicios o aplicaciones externas no identificadas de forma explícita en la información proporcionada.

5.3. Justificación del alcance

El alcance se ha definido con el objetivo de cubrir todos los elementos que pueden afectar a la seguridad de la información y a la continuidad operativa de la empresa, centrándose en los activos bajo control directo de CRP Computers. Se ha intentado evitar incluir elementos externos sobre los cuales la organización no tiene capacidad real de gestión o control, salvo en lo relativo a su impacto sobre el negocio.

6. Supuestos realizados

Debido a que la descripción proporcionada es limitada y esta práctica constituye una simulación académica, es necesario establecer ciertos supuestos de trabajo. Todos los siguientes supuestos deben entenderse como hipótesis de auditoría inicial y no como hechos confirmados.

- Se asume que cada empleado dispone de credenciales de acceso individuales para su puesto de trabajo.
- Se asume que el servidor físico central aloja funciones críticas para el negocio, tales como almacenamiento de información, gestión administrativa o servicios de soporte a la tienda online.
- Se asume que la red WIFI es utilizada por la totalidad de los puestos de trabajo y constituye el medio principal de comunicación interna.
- Se asume que no existe una segmentación formal entre áreas de red, ya que no se menciona ninguna separación entre administración, taller, tienda o servidores.
- Se asume que la empresa trata datos personales de clientes y datos de carácter comercial y económico, dada la existencia de 3500 clientes registrados, ventas diarias y actividad de reparación.
- Se asume que los equipos reparados pueden contener información personal o profesional de los clientes, lo cual introduce riesgos adicionales de confidencialidad.
- Se asume que no existe una política formal de continuidad de negocio o recuperación ante desastres, puesto que se indica que la empresa no cuenta con controles internos y no se menciona ningún mecanismo de redundancia.
- Se asume que no se dispone de infraestructura redundante para el servidor, la conectividad o el suministro eléctrico, ya que no se hace referencia a sistemas de respaldo.
- Se asume que la organización no dispone todavía de un marco formal de políticas, procedimientos o normativa interna de seguridad.
- Se asume que los privilegios de acceso de los administradores son elevados y críticos, dado que son los responsables de todos los aspectos relacionados con el servicio de informática.

Estos supuestos permiten avanzar en la delimitación del análisis sin bloquear la práctica por falta de datos concretos. No obstante, deberán ser revisados y validados en fases posteriores de la auditoría, ya que cualquier desviación respecto a ellos puede alterar la valoración del riesgo y las conclusiones obtenidas.

7. Sesión 2: Identificación, Clasificación y Valoración de Activos

Siguiendo la metodología de la auditoría, se procede a la identificación y valoración de la totalidad de los activos de CRP Computers. La "Magnitud del Daño" se cuantifica considerando la pérdida de activos o el perjuicio a la organización a corto/medio plazo.

7.1. Codificación de Activos para Trazabilidad

Para facilitar el análisis y la referencia cruzada en fases posteriores, se asignan las siguientes siglas:

- **DAT-X**: Activos de Datos e Información.
- **SIS-X**: Activos de Sistemas e Infraestructura.
- **PER-X**: Activos de Personal (Activos Humanos).

7.2. Clasificación y Valoración de Datos e Información

Cód.	Activo (Datos e Información)	Conf.	Leg.	Rec.	Magnitud del Daño
DAT-1	Base de datos de clientes (3.500)	X	X	X	Muy Alto : Violación del RGPD.
DAT-2	Credenciales de administración	X		X	Muy Alto : Control total de sistemas.
DAT-3	Historial de ventas y facturación	X	X	X	Alto : Gestión económica.
DAT-4	Órdenes y registros de reparación	X	X		Alto : Datos de terceros.
DAT-5	Inventario y Stock de almacén		X	X	Alto : Crítico para venta online.
DAT-6	Info. de proveedores y compras	X			Medio : Cadena de suministro.
DAT-7	Info. de nóminas y empleados	X	X		Medio : Datos privados.

Cuadro 2: Valoración de activos de Datos e Información.

7.3. Clasificación y Valoración de Sistemas e Infraestructura

Cód.	Activo (Sistemas e Infra.)	Exc.	Ilím.	Cos.	Magnitud del Daño
SIS-1	Servidor Físico Central	X	X	X	Muy Alto : Punto único de fallo.
SIS-2	Plataforma E-commerce (Web)		X	X	Muy Alto : Disponibilidad 24/7.
SIS-3	Red WIFI Corporativa y Fibra		X		Alto : Único medio conectividad.
SIS-4	Sala de Servidores	X		X	Alto : Espacio crítico.
SIS-5	PC Director Ejecutivo	X		X	Alto : Info. estratégica.
SIS-6	PCs Sistemas y TI (Administradores)	X		X	Muy Alto : Herramientas admin.
SIS-7	PCs Almacén	X		X	Medio : Trazabilidad logística.
SIS-8	PCs Taller	X		X	Alto : Datos de clientes.
SIS-9	PC Comercial y Ventas (TPV)	X		X	Alto : Cobros presenciales.
SIS-10	Antivirus Panda Advanced	X	X		Medio : Seguridad lógica.

Cuadro 3: Valoración de activos de Sistemas e Infraestructura.

7.4. Clasificación y Valoración de Personal (Activos Humanos)

Cód.	Personal / Rol	P. Alto	P. Med	P. Baj	Magnitud del Daño
PER-1	Director Ejecutivo	X			Muy Alto: Gobernanza.
PER-2	Administradores de Sistemas	X			Muy Alto: Privilegios totales.
PER-3	Jefe de Taller		X		Alto: Privacidad reparaciones.
PER-4	Técnicos de Montaje			X	Medio: Activos terceros.

Cuadro 4: Valoración de activos de Personal.

8. Sesión 3: Mapa de Riesgos - Amenazas y Vulnerabilidades

Siguiendo la metodología MAGERIT v3, en esta fase se identifican las amenazas que acechan a los activos y las vulnerabilidades que presentan, considerando las salvaguardas existentes en el Sistema de Información (SI) de CRP Computers.

8.1. Identificación de Salvaguardas Existentes

Antes de evaluar la debilidad, se identifican las medidas de protección actuales que limitan la vulnerabilidad del sistema:

- **S1. Antivirus Panda Advanced:** Instalado en todos los puestos de trabajo para la detección de código dañino.
- **S2. Sistema Operativo Windows 10:** Proporciona gestión de credenciales de usuario y firewall básico por software.
- **S3. Personal Especializado:** Disponibilidad de dos administradores de sistemas y técnicos de taller que actúan como salvaguarda correctiva ante averías.

8.2. Identificación de Vulnerabilidades

Tras examinar el SI, se han detectado debilidades críticas que pueden ser aprovechadas por amenazas:

- **V1. Centralización de recursos:** Dependencia total de un único servidor físico y una sede única.
- **V2. Red inalámbrica compartida:** Uso de una única red WIFI para operativa interna, clientes y gestión online sin segmentación.
- **V3. Vulnerabilidad energética:** Cortes de suministro recurrentes (5 al año) sin sistemas de respaldo (SAI/UPS).
- **V4. Deficiencia de control interno:** Ausencia de políticas formales de parches, copias de seguridad externas y auditoría de logs.
- **V5. Exposición de áreas críticas:** Zona de taller y servidores accesible desde el área pública de exposición.

8.3. Matriz de Amenazas y Probabilidad

A continuación, se relacionan los activos con las amenazas del catálogo de MAGERIT y su probabilidad de ocurrencia.

Cód.	Activo	Amenaza (MAGERIT)	Prob.	Consecuencia
Datos e Información				
DAT-1	Base de datos de clientes	[A.19] Divulgación info.	Media	Sanciones legales (RGPD).
DAT-2	Credenciales de admin.	[A.30] Ingeniería social	Alta	Control total del sistema.
DAT-3	Historial de ventas	[A.15] Modificación info.	Media	Pérdida de integridad contable.
Sistemas e Infraestructura				
SIS-1	Servidor Físico Central	[I.6] Corte suministro eléc.	Alta	Parada total del negocio (DoS).
SIS-2	Plataforma E-commerce	[A.24] Denegación servicio	Media	Interrupción ventas online.
SIS-3	Red WIFI y Fibra	[A.11] Acceso no autorizado	Media	Intercepción de tráfico.
SIS-4	Sala de Servidores	[A.25] Robo / [I.1] Fuego	Baja	Pérdida de infraestructura.
SIS-8	PCs de Taller	[A.25] Robo / [E.25] Pérdida	Media	Fuga de datos de terceros.
SIS-10	Antivirus Panda	[E.21] Error mantenimiento	Media	Infección por malware.
SIS-11	Nave Industrial	[I.1] Fuego / [I.2] Agua	Baja	Cierre de sede única.
Personal (Activos Humanos)				
PER-1	Director Ejecutivo	[A.30] Suplantación ident.	Media	Compromiso estratégico.
PER-2	Administradores Sistemas	[E.2] Errores admin.	Media	Inestabilidad del sistema.
PER-4	Técnicos de Montaje	[A.6] Abuso privilegios	Baja	Manipulación equipos clientes.

Cuadro 5: Matriz de amenazas identificadas por activo y probabilidad de ocurrencia.

8.4. Evaluación de la Vulnerabilidad (Debilidad)

Se valora la debilidad (vulnerabilidad) de la terna activo-amenaza-probabilidad, teniendo en cuenta la eficacia de las salvaguardas actuales.

Cód.	Amenaza (MAGERIT)	Prob.	Debil.	Justificación (Salvaguardas)
DAT-1	[A.19] Divulgación de info.	Media	Alta	Sin cifrado de archivos ni logs de acceso lógico.
DAT-2	[A.30] Ingeniería social	Alta	Alta	Admin. con acceso total sin MFA ni formación específica.
SIS-1	[I.6] Corte suministro eléc.	Alta	Muy Alta	Sin SAIs ni generadores para mitigar cortes recurrentes.
SIS-2	[A.24] Denegación servicio	Media	Muy Alta	Punto único de fallo; sin balanceo ni redundancia.
SIS-3	[A.11] Acceso no autorizado	Media	Muy Alta	Red DIGI/WIFI compartida sin control de acceso robusto.
SIS-4	[A.25] Robo	Baja	Media	Planta inferior accesible, aunque protegida por personal.
SIS-8	[A.25] Robo de equipos	Media	Alta	Taller contiguo a zona pública; equipos de terceros expuestos.
SIS-10	[E.21] Error mantenimiento	Media	Media	Salvaguarda S1 (Panda) mitiga riesgos de malware conocidos.
PER-2	[E.2] Errores admin.	Media	Alta	Alta carga de trabajo al gestionar todos los servicios informáticos.
PER-4	[A.6] Abuso privilegios	Baja	Media	Los técnicos operan directamente sobre activos de terceros .

Cuadro 6: Nivel de vulnerabilidad (debilidad) de los activos identificados ante las amenazas.

9. Sesión 4: Análisis y Gestión de Riesgos

En esta fase se procede a la cuantificación del riesgo intrínseco para cada una de las amenazas identificadas en la sesión anterior. El cálculo se realiza considerando la probabilidad de ocurrencia, el nivel de vulnerabilidad del activo y el valor asignado al activo según la matriz de riesgo proporcionada.

9.1. Valoración de Activos

Siguiendo una escala cuantitativa de 0 a 4 (donde 4 representa la máxima importancia para la organización), se han valorado los activos según el impacto potencial analizado en la Sesión 2:

- **Valor 4 (Muy Alto):** DAT-1 (Base de datos), DAT-2 (Credenciales admin), SIS-1 (Servidor central), SIS-2 (Plataforma E-commerce), SIS-6 (PCs Sistemas), PER-1 (Director), PER-2 (Administradores), SIS-11 (Nave industrial).
- **Valor 3 (Alto):** DAT-3 (Ventas), DAT-4 (Órdenes reparación), DAT-5 (Inventario), SIS-3 (Red y Fibra), SIS-4 (Sala servidores), SIS-5 (PC Director), SIS-8 (PCs Taller), SIS-9 (TPV), PER-3 (Jefe Taller).
- **Valor 2 (Medio):** DAT-6 (Proveedores), DAT-7 (Nóminas), SIS-7 (PCs Almacén), SIS-10 (Anti-virus), PER-4 (Técnicos).

9.2. Cálculo del Riesgo Intrínseco y Priorización

Utilizando la matriz de riesgo de la práctica, se calcula el valor para todas las ternas activo-amenaza identificadas en el mapa de riesgos. Los resultados se presentan ordenados de mayor a menor criticidad:

Cód.	Amenaza (MAGERIT)	Valor Act.	Prob.	Vulner.	Riesgo
SIS-1	[I.6] Corte suministro eléc.	4	Alta	Muy Alta	8
DAT-2	[A.30] Ingeniería social	4	Alta	Alta	7
SIS-2	[A.24] Denegación servicio	4	Media	Muy Alta	7
DAT-1	[A.19] Divulgación info.	4	Media	Alta	6
SIS-3	[A.11] Acceso no autorizado	3	Media	Muy Alta	6
SIS-8	[A.25] Robo de equipos	3	Media	Alta	6
PER-2	[E.2] Errores admin.	4	Media	Alta	6
DAT-3	[A.15] Modificación info.	3	Media	Alta	5
SIS-4	[A.25] Robo	3	Baja	Media	4
SIS-10	[E.21] Error mantenimiento	2	Media	Media	4
PER-1	[A.30] Suplantación ident.	4	Media	Media	4
PER-4	[A.6] Abuso privilegios	2	Baja	Media	3
SIS-11	[I.1/2] Fuego / Agua	4	Baja	Media	5

Cuadro 7: Cálculo de riesgo intrínseco para la totalidad de activos y amenazas detectadas.

9.3. Tratamiento del Riesgo y Propuesta de Acciones

Para cada riesgo, se ha decidido una estrategia de tratamiento basándose en su puntuación y el impacto para CRP Computers:

1. **[SIS-1] Corte suministro eléc. (Riesgo 8) - Mitigar :** Instalación urgente de Sistemas de Alimentación Ininterrumpida (SAI) de doble conversión para el servidor central y equipos críticos del taller, permitiendo la continuidad operativa durante los cortes medios de 25 minutos detectados.
2. **[DAT-2] Ingeniería social (Riesgo 7) - Prevenir:** Implantación de Autenticación Multifactor (MFA) obligatoria para las cuentas administrativas y desarrollo de un plan de concienciación en ciberseguridad para mitigar la vulnerabilidad V4.

3. **[SIS-2] Denegación servicio (Riesgo 7) - Transferir:** Contratación de un servicio de hosting gestionado con protección activa contra ataques DDoS para la plataforma e-commerce, eliminando la dependencia del servidor único físico local (V1).
4. **[DAT-1] Divulgación de info (Riesgo 6) - Prevenir:** Implementación de cifrado de archivos para la base de datos de clientes y habilitación de logs de auditoría de acceso para cumplir con el RGPD.
5. **[SIS-3] Acceso no autorizado (Riesgo 6) - Prevenir:** Segmentación física y lógica de la red WIFI de DIGI mediante la creación de VLANs independientes para administración, taller y clientes, evitando la red compartida actual (V2).
6. **[SIS-8] Robo de equipos (Riesgo 6) - Mitigar:** Instalación de medidas de seguridad física (anclajes, cámaras de seguridad) en el área de taller, dado que es contigua a la zona pública (V5).
7. **[PER-2] Errores admin. (Riesgo 6) - Mitigar:** Establecimiento de una política de “cuatro ojos” para cambios críticos y reducción de la carga de trabajo mediante la automatización de backups externos para mitigar errores por saturación.
8. **[DAT-3] Modificación info (Riesgo 5) - Prevenir:** Implementación de firmas digitales en documentos contables y backups diarios con historial de versiones para asegurar la integridad de las ventas.
9. **[SIS-4] Robo en sala servidores (Riesgo 4) - Prevenir:** Refuerzo del control de acceso a la planta inferior y cierre bajo llave de la sala de servidores durante el horario comercial.
10. **[SIS-10] Error mantenimiento (Riesgo 4) - Aceptar:** Se acepta el riesgo residual confiando en la protección actual de Panda Advanced (S1), pero programando revisiones de parches trimestrales.
11. **[PER-1] Suplantación ident. (Riesgo 4) - Prevenir:** Uso de certificados digitales personales para la validación de órdenes estratégicas enviadas por el Director Ejecutivo.
12. **[PER-4] Abuso privilegios (Riesgo 3) - Prevenir:** Firma de acuerdos de confidencialidad reforzados y limitación técnica de acceso a carpetas de red para el personal de montaje.
13. **[SIS-11] Nave Industrial (Riesgo 5) - Mitigar y Transferir:** Instalación de sistemas de detección de humos/agua y extintores adecuados para material electrónico en la sala de servidores y almacén. Además, se mantendrá la transferencia del riesgo financiero mediante un seguro multi-riesgo y se diseñará un Plan de Continuidad de Negocio (BCP) para actuar en caso de siniestro total en la sede.

10. Sesión 5: Controles y Plan de Acción

En esta fase final de la auditoría, se establecen los controles necesarios para tratar las amenazas identificadas con un nivel de riesgo igual o superior a 5. Estos controles están diseñados para fortalecer la postura de seguridad de CRP Computers basándose en la metodología MAGERIT y los dominios de la ISO 27002.

10.1. Propuesta de Controles y Resultados de la Evaluación

A continuación, se detallan las fichas de control. Se han agrupado por dominios lógicos, asegurando que todas las amenazas con riesgo superior o igual a 5 queden explícitamente cubiertas.

Título Control	[CO_01]: Resiliencia del Suministro Eléctrico
Descripción	Inspección de la infraestructura de protección eléctrica para asegurar la disponibilidad de los servicios críticos ante cortes de red.
Responsable	Administradores de Sistemas / Jefe de Taller.
Amenazas	[SIS-1] [I.6] Corte suministro eléctrico (Riesgo 8).
Resultado	Muy Deficiente. La empresa sufre 5 cortes anuales de 25 min de media y no dispone de ningún sistema SAI ni generador de respaldo.
Plan de acción	■ Adquisición e instalación de SAIs de doble conversión para el servidor y equipos de taller. ■ Implementar un protocolo de apagado automático ordenado para cortes prolongados.

Título Control	[CO_02]: Formación y Concienciación en Seguridad
Descripción	Verificación del programa de formación continua para prevenir ataques basados en el factor humano y errores de administración.
Responsable	Director Ejecutivo.
Amenazas	[DAT-2] [A.30] Ingeniería social (Riesgo 7) y [PER-1] [A.30] Suplantación identidad.
Resultado	Inexistente. No se han realizado sesiones de formación; el personal desconoce los vectores de ataque de phishing.
Plan de acción	■ Implantación de Autenticación Multifactor (MFA) obligatoria en cuentas de administración. ■ Realizar talleres semestrales sobre ciberseguridad y prevención de fraude.

Título Control	[CO_03]: Protección Perimetral y Segmentación
Descripción	Evaluación de la arquitectura de red y la exposición de servicios externos (E-commerce).
Responsable	Administradores de Sistemas.
Amenazas	[SIS-2] [A.24] Denegación servicio (Riesgo 7) y [SIS-3] [A.11] Acceso no autorizado (Riesgo 6).
Resultado	Muy Deficiente. Red WIFI única compartida y dependencia de un servidor físico local para la web de ventas.
Plan de acción	■ Migración de la plataforma E-commerce a un hosting gestionado con protección DDoS. ■ Creación de VLANs aisladas para separar el tráfico de clientes de la gestión interna.

Título Control	[CO_04]: Cifrado y Auditoría de Información
Descripción	Inspección de los mecanismos de protección técnica para los datos personales y financieros.
Responsable	Administradores de Sistemas / Administrativo.
Amenazas	[DAT-1] [A.19] Divulgación info (Riesgo 6) y [DAT-3] [A.15] Modificación info (Riesgo 5).
Resultado	Deficiente. Ausencia de cifrado en base de datos y falta de logs de auditoría para el cumplimiento del RGPD.
Plan de acción	■ Activar cifrado AES-256 en el servidor de base de datos. ■ Implementar firmas digitales y backups con control de versiones para evitar modificaciones.

Título Control	[CO_05]: Control de Acceso a Áreas Críticas
Descripción	Verificación de las barreras físicas que protegen el taller y los equipos de terceros.
Responsable	Jefe de Taller.
Amenazas	[SIS-8] [A.25] Robo de equipos (Riesgo 6) y [SIS-4] [A.25] Robo.
Resultado	Deficiente. El área de taller es fácilmente accesible por clientes; los activos de terceros no tienen anclajes.
Plan de acción	■ Instalación de videovigilancia (CCTV) y mejora de los cierres físicos en el taller. ■ Protocolo de custodia bajo llave para equipos de clientes fuera del horario laboral.

Título Control	[CO_06]: Control de Operaciones y Administración
Descripción	Supervisión de las tareas técnicas para evitar errores humanos en la gestión del servidor único.
Responsable	Administradores de Sistemas.
Amenazas	[PER-2] [E.2] Errores admin (Riesgo 6).
Resultado	Deficiente. Los administradores operan sin procedimientos de doble validación y con alta carga de trabajo.
Plan de acción	■ Implementar política de “doble check” para cambios críticos en el servidor. ■ Automatización de tareas de mantenimiento y backups externos en la nube.

Título Control	[CO_07]: Protección contra Desastres Físicos y Continuidad de Negocio
Descripción	Revisión e implantación de medidas físicas de protección contra incendios e inundaciones, y evaluación de un plan de contingencia ante pérdida de la sede.
Responsable	Director Ejecutivo / Administrador de Sistemas.
Amenazas	[SIS-11] [I.1/I.2] Fuego / Agua (Riesgo 5) y [SIS-4] [A.25] Robo (Riesgo 4).
Resultado	Muy Deficiente. Sede única sin detectores automáticos ni plan de contingencia. Un siniestro ambiental supondría la paralización total de la empresa.
Plan de acción	■ Instalar sistemas de detección automática de humos y sensores de inundación en la planta inferior (sala de servidores y almacén). ■ Colocar extintores de CO2 específicos para riesgo eléctrico en la sala del servidor. ■ Elaborar un Plan de Continuidad de Negocio (BCP) que contemple teletrabajo temporal y recuperación del servidor en un entorno cloud. ■ Contratar una póliza de seguro multirriesgo ampliada que cubra el cese de actividad y el valor de los equipos de terceros.

10.2. Conclusiones de la Auditoría

Tras el análisis exhaustivo e incremental realizado a lo largo de las cinco sesiones sobre el Sistema de Información de CRP Computers, se concluye que la organización presenta un **nivel de madurez inicial muy deficiente** en materia de ciberseguridad y continuidad de negocio. La empresa ha operado hasta la fecha sin un marco formal de controles, asumiendo riesgos críticos que podrían comprometer su viabilidad a corto plazo.

Los resultados de la auditoría evidencian que el perfil de riesgo de la empresa está fuertemente marcado por una doble dependencia que genera **puntos únicos de fallo** inasumibles:

- **Vulnerabilidad Física e Infraestructural:** Toda la actividad logística, técnica, administrativa y de ventas presenciales (que supone aproximadamente el 65 % de los ingresos) se concentra en una única nave industrial. La ausencia de un Plan de Continuidad de Negocio (BCP) frente a desastres ambientales (fuego/agua) o cortes eléctricos prolongados amenaza con la paralización total e inmediata de la empresa.
- **Vulnerabilidad Tecnológica y Lógica:** La centralización absoluta de los servicios en un único servidor físico local, sumado al uso de una red inalámbrica plana (sin segmentar) y a la carencia de alta disponibilidad para el portal de e-commerce, exponen a la empresa a tiempos de inactividad críticos y ataques externos.
- **Cumplimiento y Privacidad (RGPD):** Las deficiencias en el control de accesos lógicos, la falta de cifrado y la exposición física de los equipos de terceros en el taller suponen un alto riesgo de sanción legal y daño reputacional.

Para mitigar este escenario, se ha diseñado un **Plan de Acción compuesto por 7 controles de cumplimiento obligatorio** (orientados a mitigar todos los riesgos evaluados con un nivel igual o superior a 5).

La implementación inmediata de este plan no debe concebirse como un gasto operativo, sino como una **inversión crítica y estratégica**. Su ejecución es el único camino viable para reducir el riesgo residual a niveles aceptables, asegurar el cumplimiento normativo legal y, en última instancia, garantizar la resiliencia y supervivencia de CRP Computers ante cualquier incidente físico o cibernético.